WICYS 2026

Human Communication at Machine Speed

Critical Vulnerability Response

Beatriz Datangel Rodgers · Head of Product Marketing, Root

Maryland D · 10:45 AM · 45 min

SLIDE

2 MIN

📚 What We're Talking About (and Not)

This is a talk about **skills and communication systems**, not building agents.

What we're covering

- **AI skills:** Simple, repeatable prompts + workflows you can run in any approved AI tool.
- **How to leverage AI:** Using AI to research CVEs and draft clearer, faster incident comms.
- **Communication systems:** Lightweight structures you can plug into your existing IR process.

Out of scope today

- **Agents:** Long-running or autonomous systems that act on your behalf.
- **No AI decisions:** AI is not deciding severity, disclosure timing, or legal moves.
- **No legal or full IR design:** This is the comms layer — not breach law or full SOC playbooks.

Goal: you leave with **one or two concrete skills** you can ship this quarter.

🚨 When the CVE Drops

🔴 Critical CVE just published. CVSS 9.8.
📞 CEO: "Are we exposed?"
👥 12 teams across 6 time zones waiting on your answer.
⏱️ First update is due in under 2 hours.

What do you send first?

SLIDE

3 MIN

👋 The Persistent Pattern

Women in security are often holding the comms line in a crisis.

- **Supply chain attacks accelerating**
  Log4j (2021) → SolarWinds (2020) → constant stream of critical CVEs
- **Technical response has evolved**
  Scanning, patching, AI remediation — better than ever
- **Communication still breaks down**
  The gap isn't technical — it's human

> *This talk is the framework I wish I'd had the first time.*

SLIDE

5 MIN

😱 What Breaks Down

What didn't work:

- **Vague:** "Limited customers may be affected"
- **Delayed:** 48+ hours before first update
- **No action:** "We're investigating" — full stop
- **No timeline:** "We'll update when we know more"

Result: Confusion, duplicated effort, trust erosion

The checklist:

- ❌ No vague impact without specific scope
- ❌ No delays before first comm (<2 hours)
- ❌ No missing "what to do"
- ❌ No missing "when we'll update next"
- ❌ No communicating without knowing your own exposure first (SBOM)

A framework prevents these by design.

SLIDE

6 MIN

📺 What Worked and What Didn't

INCIDENT	✅ WHO GOT IT RIGHT	💡 WHY IT MATTERS
XZ Utils 2024 · CVE-2024-3094	• **Red Hat:** "STOP USAGE" within hours • **Andres Freund (Microsoft):** clear, factual oss-security write-up	• Caught by **one engineer's curiosity**, not process • Shows how **long a motivated attacker can hide** without strong process
Shai-Hulud 2.0 2025 · CVE-2025-66478	• **Postman:** packages unpublished by 3:30am • **Elastic:** transparent about CI exposure	• 700+ packages hit across the ecosystem • No **single source of truth** for impacted packages
React2Shell 2025 · CVE-2025-55182	• **Vercel + Meta:** pre-deployed WAF rules before public CVE • Coordinated messaging on impact and mitigations	• Attackers exploited it within hours of disclosure • **Downstream Next.js users** didn't know they were exposed

> *The pattern is clear. Transparency + Speed + Action + Structure. It's not magic — it's a system.*

SLIDE

8 MIN

📋 The Framework: Two AI Skills

1. SECURITY CHECK

What it does: Looks up the CVE (NVD, GitHub Advisories, vendor pages), builds a factual summary with timeline.

In: CVE-ID (or paste advisory text)

Out: Summary + timeline + ecosystem impact

`/security-check cve [CVE-ID]`

2. SECURITY BRIEF

What it does: Writes audience-specific messages. Same structure, different tone.

In: CVE research + audience

Out: Message draft (Slack, Email, Status)

`/security-brief cve-executive [CVE-ID]`

Every message: Target · Impact · Action · Next update · Unknowns

Full prompts: github.com/dat-angel/AI-Cyber-Guide

SLIDE

3 MIN

👥 Security Brief: Three Audiences

Same framework (Target + Impact + Action + Update + what you don't know). Different tone.

👔 EXECUTIVE

Target: C-suite

Message: Business impact, scope, risk

Channel: Email · **Timing:** Immediate

`"500 systems. CVSS 9.8. Patches rolling. Update 18:00."`

👥 CUSTOMER/PARTNER

Target: External

Message: What happened, what we're doing, what you should do

Channel: Email · **Timing:** As needed

`"Vuln in Chromium. We're patching. Update your browser."`

🏃 ENGINEERING

Target: Eng / SRE

Message: Severity, action, next update

Channel: Slack · **Timing:** Immediate

`"🔴 CVE-2026-2441. Update NOW. Huddle 18:00."`

Don't forget: Downstream dependency users — people who don't know your code is in their stack.

SLIDE

3 MIN

⏱️ Detection → Remediation

- **Coordinated disclosure:** "Align with vendors, pre-deploy mitigations before public CVE." (Vercel + Meta did this for React2Shell)
- **Detection:** "CVE detected. Assessing. Update in 2 hours."
- **Assessment:** "Affects X systems. Here's what we know. Here's what we don't know yet."
- **Mitigation:** "50% patched. Coordinating with ecosystem vendors on affected-package list."
- **Resolved:** "Post-mortem scheduled for [date]."

Tools like **Root** (root.io) surface exposure and help draft structured comms at each stage.

❌ **BEFORE**

"We're seeing concerning activity that may impact a subset..."

✅ **AFTER**

"Critical vuln at 09:00 EST. 500 affected. Patch ready. Deploying now. Update: 15:00 EST."

SLIDE

2 MIN

So what's the play?

7-day challenge: Download → Set up → Test → Tabletop

Challenge:

- github.com/dat-angel/AI-Cyber-Guide
- Set up skills · Works with any AI
- Test: `/security-check cve` then `/security-brief cve-executive`
- Can you answer "are we affected?" in <1 hour?
- Run a tabletop with your team

Three Takeaways:

- Communication fails → **no structure**
- **Repeatable framework** → coordination
- AI tools → **automate** CVE comms

> *The next critical CVE is coming. Will your team be ready?*

Let's Connect

This framework is for you. Use it. Share it.

github.com/dat-angel/AI-Cyber-Guide

aicyberguide.com · Root (root.io)

GitHub · Script & slides

LinkedIn

@bzdata | beatriz.page